

Vulnerability Assessment and Penetration Testing (VAPT)

Simulated Lab Environment – Metasploitable2 Target

Prepared by: Swastik Chowdhury

B-Tech in CSE (7th Semester) , University of Kalyani

Date: 25 August 2026

***Classification: Internal / Academic – Isolated Lab
Environment Only***

1. Executive Summary

This report documents a Vulnerability Assessment and Penetration Test (VAPT) carried out against a deliberately vulnerable virtual machine (Metasploitable2) hosted in an isolated lab environment. The objective was to identify security weaknesses in exposed network services and demonstrate their real-world impact through controlled exploitation, in line with standard ethical hacking methodology.

The assessment identified a critical vulnerability in the FTP service (vsftpd 2.3.4) running on the target, which contains a known backdoor. This vulnerability was successfully exploited, resulting in unauthenticated remote root access to the target system — the highest possible severity of compromise. An outdated SSH service was also identified during reconnaissance.

All testing was performed exclusively within a private, host-only virtual network against a system built specifically for security training. No production systems, third-party networks, or real-world targets were accessed at any point.

2. Scope

Objective: Identify vulnerabilities in a simulated environment and perform penetration testing to exploit weaknesses

Target: Metasploitable2 virtual machine (192.168.1.3)

Attacker host: Kali Linux virtual machine (192.168.1.4)

Host system: Windows PC running VirtualBox

Network: Isolated host-only virtual network – no internet or LAN exposure

Authorization: Self-owned lab VMs built specifically for security training; no external systems in scope

Tools used: Nmap, Metasploit Framework (msfconsole), and VirtualBox for lab virtualization. Burp Suite and Nessus were set up as part of the lab toolkit for web application and broader vulnerability scanning.

3. Methodology

The assessment followed the standard VAPT lifecycle:

- Lab setup – isolated attacker (Kali) and target (Metasploitable2) VMs on a shared host-only network
- Reconnaissance – connectivity verification between attacker and target
- Scanning – Nmap port, service, and version enumeration against the target
- Vulnerability identification – mapping identified service versions to known vulnerabilities
- Exploitation – using the Metasploit Framework to actively exploit the identified vulnerability
- Post-exploitation verification – confirming privilege level and system access gained
- Reporting – documenting findings, evidence, impact, and remediation

4. Reconnaissance and Scanning

Network connectivity between the Kali attacker VM and the Metasploitable2 target was first confirmed by IP reachability. A full TCP port scan with service/version detection was then run from Kali against the target:

Command used:

```
nmap -sV -sC -p- 192.168.1.3
```

The scan identified two open TCP ports of interest:

Port/Service	Version	Severity	Finding
21/tcp – FTP	vsftpd 2.3.4	Critical (CVSS ~10.0)	Backdoor command execution (CVE-2011-2523). Anonymous FTP login also enabled.
22/tcp – SSH	OpenSSH 4.7p1 (Debian 8ubuntu1)	Informational / Low	Outdated OpenSSH version identified during reconnaissance; not exploited in this assessment.

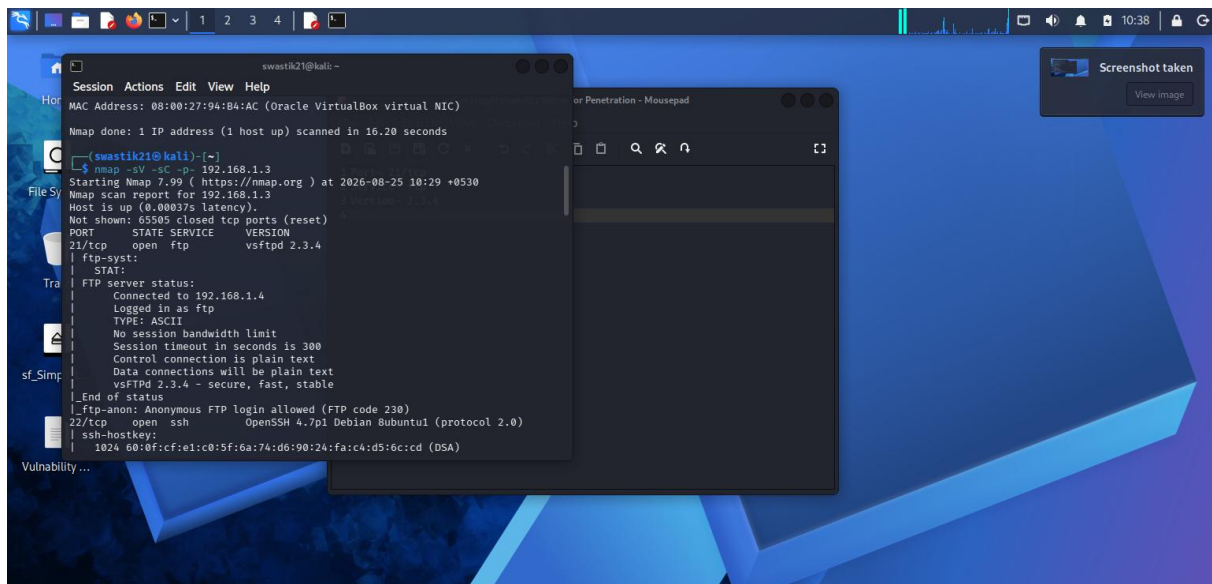


Figure 1: Nmap scan output showing open ports 21 (vsftpd 2.3.4) and 22 (OpenSSH 4.7p1) on 192.168.1.3

5. Vulnerability Analysis

5.1 vsftpd 2.3.4 Backdoor (Critical)

The FTP banner returned by the target (“vsFTPd 2.3.4”) matches a known malicious build of vsftpd distributed between June and July 2011, in which the source code was compromised to include a backdoor. Any connection attempt using a username containing the sequence “:”) triggers a listener on TCP port 6200 that grants an unauthenticated remote shell, tracked as CVE-2011-2523. The scan additionally confirmed anonymous FTP login was permitted, widening the exposure of this service.

5.2 Outdated OpenSSH (Informational)

Port 22 was found running OpenSSH 4.7p1 on Debian, an old release with several publicly documented issues associated with that era of OpenSSH/Debian builds. This service was catalogued during reconnaissance but was not exploited as part of this assessment, since the FTP backdoor already provided a complete compromise path.

6. Exploitation

The vsftpd 2.3.4 backdoor was exploited using the Metasploit Framework.

Steps performed:

- Launched msfconsole on the Kali attacker VM
- Selected module: exploit/unix/ftp/vsftpd_234_backdoor
- Configured RHOSTS = 192.168.1.3 (target) and LHOST = 192.168.1.4 (attacker, for the reverse handler)
- Executed the module with the run command

The exploit's automatic vulnerability check confirmed the target was vulnerable based on the FTP banner, after which the backdoor was triggered and a Meterpreter session was established on the target.

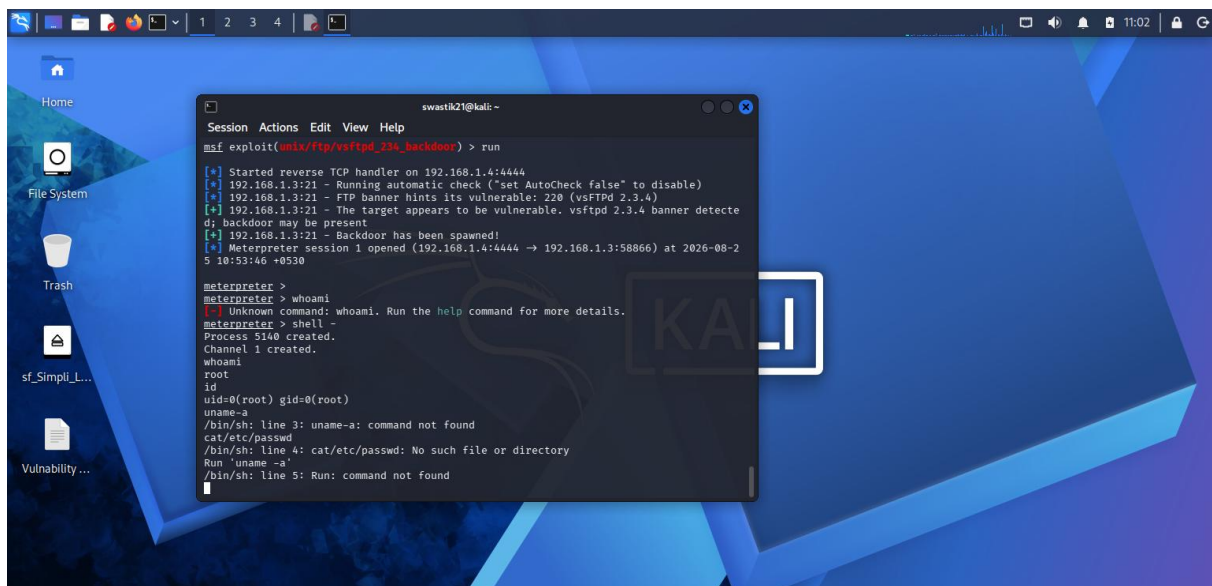


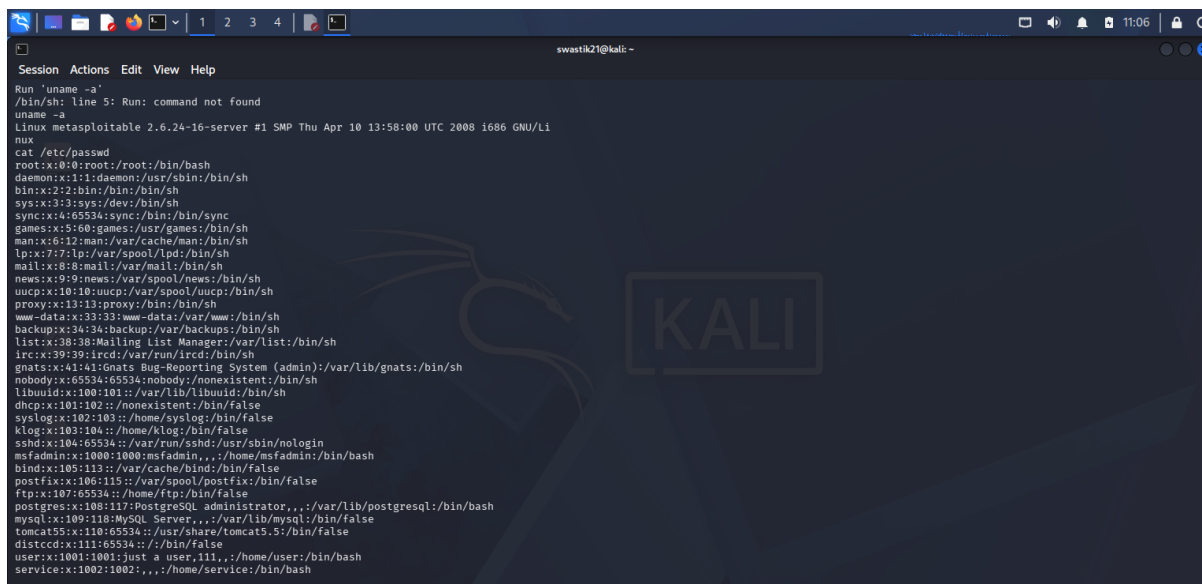
Figure 2: Metasploit successfully triggering the vsftpd backdoor and opening a Meterpreter session

7. Post-Exploitation and Impact

From within the established session, a system shell was obtained and privilege level was verified. The output confirmed root-level access was granted directly upon exploitation, with no privilege escalation required:

- whoami → root
- id → uid=0(root) gid=0(root)
- uname -a → Linux metasploitable 2.6.24-16-server, i686
- Full contents of /etc/passwd were readable, exposing all system and application user accounts

This represents complete compromise of the target system. An attacker in this position could read, modify, or delete any file, create persistent backdoor accounts, pivot to other systems on the network, or use the host to launch further attacks — all from a single unauthenticated connection to the FTP service.



```

Run 'uname -a'
/bin/sh: line 5: Run: command not found
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuid:x:100:101:/var/lib/libuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin::/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator::/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server::/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/bin/false
user:x:1001:1001:just a user,111,,/home/user:/bin/bash
service:x:1002:1002::/home/service:/bin/bash

```

Figure 3: Confirmed root access (uid=0) and full /etc/passwd disclosure on the compromised target

8. Risk Rating Summary

Finding	Severity	Impact
vsftpd 2.3.4 backdoor (CVE-2011-2523)	Critical	Full unauthenticated remote root compromise
Anonymous FTP login enabled	Medium	Unauthorized access to FTP file storage
Outdated OpenSSH 4.7p1	Low / Informational	Increased attack surface; not exploited in this test

9. Nessus Vulnerability Scanning

Nessus Essentials was deployed as an automated vulnerability scanner to independently verify the target's security posture. A Basic Network Scan was configured against target 192.168.1.3 without authentication (simulating an external attacker's view).

Scan Results:

- Total vulnerabilities detected: 10
- Most significant finding: DNS Server Cache Snooping Remote Information Disclosure (CVSS 5.3, Medium severity)
- Additional findings: primarily informational (DNS, port scanner discovery, general configuration details)
- Scan duration: 5 minutes

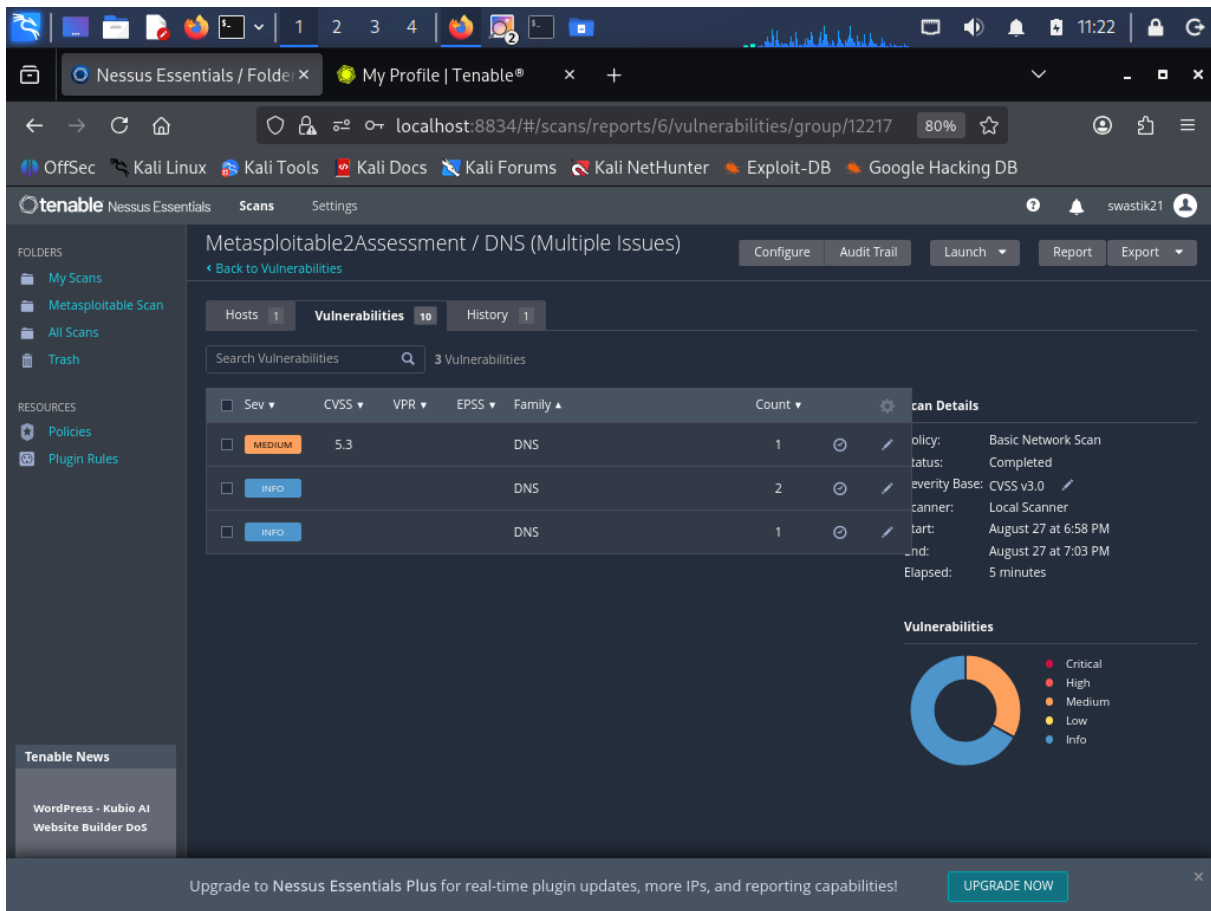


Figure 4: Nessus scan findings detail showing DNS Server Cache Snooping vulnerability (CVSS 5.3) with full description and remediation guidance

The Nessus scan provided independent confirmation of the target's vulnerable state and demonstrated automated vulnerability assessment capabilities complementary to manual Nmap enumeration.

10. Burp Suite Web Application Testing

Burp Suite Community Edition was configured as a man-in-the-middle proxy to intercept and analyze HTTP traffic between the attacker (Kali) and DVWA (Damn Vulnerable Web Application) running on the target. This demonstrated web application vulnerability testing methodology.

Configuration & Setup:

- Firefox browser configured to route HTTP/HTTPS traffic through Burp proxy listener on 127.0.0.1:8080
- Burp's Proxy → Intercept feature enabled to capture all requests in real-time
- Repeater tool configured to allow crafting, modifying, and resending individual HTTP requests

Testing Demonstrated:

- Identified DVWA SQL Injection (SQLi) vulnerability page at /dvwa/vulnerabilities/sqli/
- Captured baseline GET request with legitimate `id=1` parameter
- Crafted SQL injection payload: `id=1' OR '1'='1` to test for authentication bypass
- Sent modified request via Repeater tool to demonstrate exploitation attempt

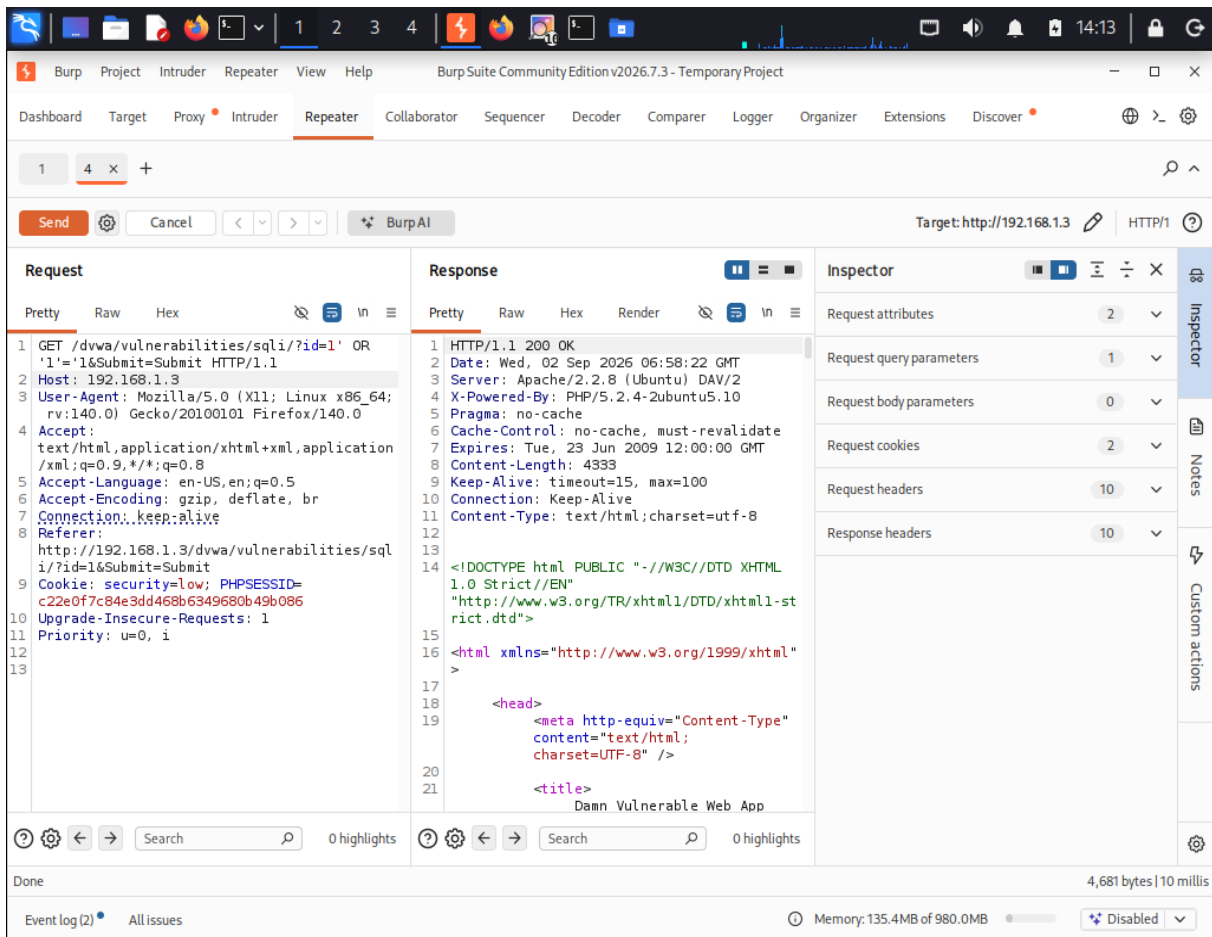


Figure 5: Burp Suite Repeater showing crafted SQL injection payload (id=1' OR '1'='1&Submit=Submit) being sent to DVWA target, demonstrating web app vulnerability testing methodology

This exercise demonstrated Burp Suite's role in VAPT workflows: intercepting traffic, identifying injection points, crafting malicious payloads, and analyzing responses to confirm vulnerabilities in web applications.

11. Remediation Recommendations

- Remove the compromised vsftpd 2.3.4 build immediately and upgrade to the latest stable, officially distributed release of vsftpd
- Disable anonymous FTP login unless explicitly required for business purposes
- Verify the integrity of all installed packages against official checksums after any suspected supply-chain compromise
- Upgrade OpenSSH to a current, supported version and disable weak ciphers/protocols
- Implement a regular patch management process to prevent deployment of known-vulnerable software versions
- Restrict FTP and SSH exposure using network segmentation or a firewall, allowing access only from trusted hosts
- Deploy an intrusion detection system (IDS) to flag anomalous FTP authentication patterns, such as the “:)” backdoor trigger
- Remediate DNS cache snooping by restricting recursive queries to authorized clients only, and implementing DNSSEC validation
- Implement input validation and parameterized queries (prepared statements) to prevent SQL injection vulnerabilities in web applications

12. Conclusion

This assessment demonstrated the complete compromise of a target system through a single critical vulnerability in an outdated FTP service. The exercise highlights how a single unpatched, backdoored service can lead directly to full root-level system access without requiring any credentials or additional privilege escalation. It underscores the importance of maintaining up-to-date software, verifying package integrity, and minimizing unnecessary exposed services in any production environment.

This engagement was conducted entirely within an isolated, self-owned virtual lab for educational purposes, in accordance with ethical hacking principles.